Responsible Administrator: CISO
Responsible Office: Office of Technology
Effective Date: 08/18/2026
Approved by: President
Date of Revision: 08/18/2026

Information Security Policy

Policy Statement

The information assets of Southeastern Louisiana University are vital to its mission of education, research, and service. This Information Security Policy sets forth guidelines, standards, and procedures to protect university information from unauthorized access, disclosure, alteration, and destruction. Its purpose is to provide guidance to senior leadership in developing and implementing an Information Security Program aimed at safeguarding the confidentiality, security, and integrity of information entrusted to the University.

Purpose of Policy

The university is committed to maintaining the confidentiality, integrity, and availability of its information assets. This section of the Information Security Policy outlines the university's compliance obligations under various federal and state laws and regulations, including the Gramm-Leach-Bliley Act (GLBA), Health Insurance Portability and Accountability Act (HIPAA), Higher Education Act (HEA), and Family Educational Rights and Privacy Act (FERPA) among others. Adherence to these regulations is crucial to protect sensitive information and to ensure the university meets its legal and ethical responsibilities.

Definitions

Gramm-Leach-Bliley Act (GLBA)**:** The GLBA mandates that financial institutions, including universities, protect the privacy of consumers' financial information. As part of our compliance with GLBA, the university will:

- Develop, Implement, and Maintain an Information Security Program: This program will include administrative, technical, and physical safeguards designed to protect nonpublic personal information (NPI) related to students and staff.
- Appoint a Security Program Coordinator: The CISO will oversee the implementation and enforcement of the GLBA Information Security Program.
- Conduct Risk Assessments: Regularly assess risks to the confidentiality and security of NPI and implement appropriate measures to mitigate identified risks.
- Implement Safeguards: Ensure proper security measures are in place to protect NPI, including encryption, access controls, and secure disposal methods.
- Service Provider Oversight: Ensure that third-party service providers handling NPI adhere to GLBA requirements through proper contractual agreements and regular assessments (e.g., SOC2 reviews).

Health Insurance Portability and Accountability Act (HIPAA)**:** HIPAA sets standards for the protection of health information. The university, when applicable within its health services and other departments, will comply with HIPAA by:

- Ensuring Privacy and Security of Protected Health Information (PHI): Implement administrative, technical, and physical safeguards to protect the privacy and security of PHI.
- Designating a HIPAA Privacy Officer: The CISO will oversee HIPAA compliance, manage privacy-related issues, and ensure that policies and procedures are in place and followed.

- Incident Response: Establish procedures for responding to breaches involving PHI, including notification requirements and mitigation strategies.

Higher Education Act (HEA)**:** The HEA includes provisions related to the security and privacy of student financial aid information. To comply with the HEA, the university will:

- Protect Student Financial Aid Information: Implement security measures to protect the confidentiality and integrity of student financial aid data.
- Data Access Controls: Ensure that access to student financial aid information is restricted to authorized personnel only.
- Information Disclosure Policies: Develop and enforce policies regarding the disclosure of student financial aid information in compliance with the HEA.
- Reporting and Notifications: Maintain accurate records and provide necessary disclosures and reports as required by the HEA.

Family Educational Rights and Privacy Act (FERPA)**:** FERPA protects the privacy of student education records. In compliance with FERPA, the university will:

- Control Access to Education Records: Ensure that access to student education records is limited to individuals with a legitimate educational interest.
- Provide Student Rights to Access and Amend Records: Allow students to access their education records and request amendments to inaccurate or misleading information.
- Obtain Consent for Disclosure: Obtain written consent from students before disclosing personally identifiable information from their education records, except as permitted under FERPA.
- Annual Notification: Inform students annually of their rights under FERPA.

Payment Card Industry Data Security Standard (PCI DSS)**:** PCI DSS establishes a set of security standards designed to protect cardholder data and ensure the safe handling of payment card information by merchants, service providers, and organizations. The university will:

- Use Approved Devices Only: Ensure all devices used to process or store cardholder data are PCI DSS-compliant and approved by the university. Non-approved devices or software must not be used in cardholder data environments (CDE).
- Access Controls: Limit access to cardholder data to authorized personnel using approved devices. Enforce strong authentication methods (e.g., unique user IDs and multi-factor authentication) for those accessing devices handling cardholder data.
- Data Protection & Encryption: Ensure cardholder data is encrypted at rest and during transmission between approved devices, in compliance with PCI DSS standards.
- Security Awareness & Vendor Management: Conduct annual security awareness training for personnel handling cardholder data and ensure third-party vendors comply with PCI DSS requirements for device and data security.

Other Relevant Regulations

The university will also adhere to additional regulations that impact information security, including but not limited to:

- State Data Protection Laws: Comply with applicable state laws regarding the protection of personal information, data breach notification requirements, and consumer privacy rights.

Applicability

This policy applies to all faculty, staff, students, contractors, and third-party entities who access, use, or manage university information systems, networks, and data resources.

Policy Procedure

Risk Assessment

The university will identify and assess the risks that may threaten the security, confidentiality, or integrity of university data and systems. The university will:

- Identify reasonably foreseeable internal and external threats that could result in unauthorized disclosure, misuse, alteration, or destruction of university data and systems.
- Assess the likelihood and potential damage of these threats taking into consideration the sensitivity of university data.
- Assess the sufficiency of policies, procedures, systems, and other arrangements in place to control risks.

Information Security Responsibilities

- Senior Leadership: The university's senior leadership is responsible for providing oversight, direction, and support for information security initiatives, including the allocation of resources and the establishment of a culture of security awareness.
- Chief Information Security Office (CISO): The CISO is responsible for developing, implementing, and enforcing information security policies, procedures, and controls, as well as coordinating security efforts across the university.
- Data Stewards: Data stewards are responsible for defining data classification levels, access controls, and handling requirements for university data within their respective areas of responsibility.
- System Administrators: System administrators are responsible for implementing and maintaining security controls, patches, and configurations for information systems and infrastructure under their management. This role can fall outside the Office of Technology.
- Users: All users are responsible for safeguarding university information assets, complying with security policies and procedures, and reporting security incidents or concerns to the appropriate authorities.

Information Security Controls

- Access Control: Access to university information systems, networks, and data resources must be restricted to authorized individuals based on the principle of least privilege. User access rights should be reviewed and updated regularly to reflect changes in job roles or responsibilities.
- Data Protection: University data must be classified according to its sensitivity and criticality, and appropriate safeguards must be implemented to protect it from unauthorized access, disclosure, or loss.
- Network Security: Network connections must be secured using firewalls, intrusion detection/prevention systems, encryption, and other security controls to prevent unauthorized access and data interception.
- Vulnerability Management: Vulnerability management is a critical component of our information security controls, ensuring the ongoing protection of our systems and data. The organization will implement a structured process to identify, assess, and remediate vulnerabilities across all assets. This includes regular vulnerability scanning, timely patch management, and the application of security updates. Identified vulnerabilities will be prioritized based on risk, with critical and high-risk issues addressed promptly to minimize potential impact. The vulnerability management process will be continuously monitored and adjusted to address emerging threats, ensuring the resilience and security of our infrastructure.
- Endpoint Security: Endpoint devices (e.g., desktops, laptops, mobile devices) must be protected with antivirus/anti-malware software, disk encryption, and other security measures to prevent malware infections and unauthorized access.
- Physical Security: Physical access to university facilities, data centers, server rooms, and other sensitive areas must be controlled using methods like access controls, surveillance cameras, and security patrols to prevent unauthorized entry or tampering.
- Incident Response: A formal incident response plan must be in place to address security incidents, including procedures for detection, containment, eradication, recovery, and post-incident analysis.
- Monitoring: The university will utilize monitoring systems and procedures consistent with industry standards to detect and retain a record of actual and attempted attacks on or intrusions into information systems and protect against data leakage wherever feasible.

- Encryption: The university will provide encryption for data when appropriate and feasible including while in transit or in storage on networks, systems, or computers to which unauthorized individuals may have access.
- Remote Work: Employees are required to ensure secure practices while working remotely. This includes preferring university workstations over personal workstations for university business, maintaining secure connections (e.g., encrypted connections, virtual machine connections, VPN, multi factor authentication, etc.), and safeguarding devices when unattended (e.g., locking screen, not leaving laptops in cars, etc.).
- Personal Devices: Employees must ensure that university data on personal devices is adequately protected (e.g., lock screens on mobile phones, passwords on personal computers, etc.) to prevent unauthorized access in the event of loss or theft. Employees should limit what university data is kept on personal devices.
- Email: Users should avoid sending confidential data through email unless it is encrypted, and should never click on suspicious links or open attachments from unknown sources. Report any suspicious emails to the IT department immediately. Personal email accounts should not be used for work-related communications, especially when handling sensitive information. Work-related email accounts should not be used for personal communication as it increases the risk of accidentally exposing sensitive work-related information or falling victim to phishing attacks through less secure personal contacts.
- Passwords: Passwords must be strong, unique, and adhere to specific security requirements to protect access to sensitive systems and data. All university-controlled systems must be configured to require users to create passwords that are at least 12 characters long, combining upper and lowercase letters, numbers, and special characters when possible. Passwords should not be reused or shared. Accounts will be locked after multiple failed login attempts to prevent unauthorized access, and multi-factor authentication (MFA) is required for accessing sensitive or critical systems when available.
- Secure Customer Information Disposal: The university will ensure the secure disposal of customer information when it is no longer needed, using methods that are appropriate and feasible. This includes the physical destruction of paper records and the secure erasure of digital data on networks, systems, or devices to which unauthorized individuals may have access.

Security Awareness and Training

- Security Awareness: All faculty and staff must receive regular security awareness training to educate them about cybersecurity risks, best practices, policies, and procedures.
- Training Programs: Training programs should cover topics such as phishing awareness, password security, data handling, social engineering, and incident reporting to promote a culture of security awareness throughout the university community.
- Security Staff Training: In order to reasonably ensure that the Information Security Program is effective and meets current industry standards, information security training for security staff is essential. It is critical that key employees have the expertise and skills necessary to perform their information security functions and are properly trained.

Policy Compliance and Enforcement

- Compliance: All users must comply with this Information Security Policy and related security policies, standards, and procedures established by the university.
- Enforcement: Violations of this policy may result in disciplinary action, including but not limited to warnings, suspension of access privileges, termination of employment, and legal prosecution as appropriate.

Policy Review and Updates

This Information Security Policy will be reviewed annually and updated as needed to reflect changes in technology, regulations, and security risks. All revisions to the policy will be communicated to university stakeholders and made available through appropriate channels.

[End of Policy]